

9. Caso de Discusión

Caso: Incidente de Seguridad en Uber (2022)

Contexto del caso

En septiembre de 2022, Uber fue víctima de un incidente de seguridad ampliamente difundido a nivel mundial. El ataque no se produjo mediante una vulnerabilidad técnica compleja, sino a través de una combinación de ingeniería social, gestión inadecuada de identidades y deficiencias en el monitoreo continuo.

El atacante identificó a un contratista externo que tenía acceso a sistemas corporativos de Uber. Mediante técnicas de ingeniería social obtuvo credenciales válidas y posteriormente inició múltiples solicitudes de autenticación multifactor (MFA Push).

Durante aproximadamente una hora, el contratista recibió repetidas notificaciones MFA en su dispositivo móvil. Finalmente, cansado de las solicitudes o confundido respecto a su origen, aprobó una de ellas, permitiendo el acceso inicial del atacante.

Cronología simplificada del incidente

Fase 1: Obtención de credenciales

El atacante obtuvo las credenciales del contratista mediante técnicas de ingeniería social y posiblemente información expuesta en canales externos.

Activo comprometido:

- Cuenta corporativa de un contratista.

Amenaza:

- Ingeniería social.

Vulnerabilidad:

- Dependencia excesiva de la autenticación MFA basada en aprobación manual.
- Falta de capacitación suficiente frente a ataques de MFA Fatigue.

Fase 2: Acceso inicial

Una vez obtenidas las credenciales, el atacante comenzó a enviar múltiples solicitudes MFA hasta lograr que una fuera aprobada.

Señales de alerta potenciales:

- Decenas de solicitudes MFA rechazadas en un corto período.
- Intentos de autenticación desde ubicaciones inusuales.
- Horarios atípicos de acceso.

Pregunta para los alumnos:

¿Existían KRIs o alertas que hubieran permitido detectar esta situación antes de que se concretara el acceso?

Fase 3: Escalamiento y movimiento lateral

Después de ingresar a la red corporativa, el atacante encontró información sensible almacenada en recursos internos.

Según reportes públicos, logró acceder a:

- Herramientas administrativas.
- Consolas internas.
- Sistemas de gestión corporativa.
- Repositorios de código fuente.
- Información relacionada con infraestructura tecnológica.

El atacante incluso publicó mensajes en canales internos para demostrar el acceso obtenido.

Activos afectados:

- Sistemas administrativos.
- Repositorios de desarrollo.
- Herramientas de gestión de identidades.
- Información corporativa.

Posibles vulnerabilidades identificadas:

- Exceso de privilegios.
- Segmentación insuficiente de accesos.
- Gestión inadecuada de cuentas privilegiadas.
- Falta de controles Zero Trust.

Fase 4: Detección y respuesta

Una vez identificado el incidente, Uber inició acciones de contención:

- Deshabilitación de accesos comprometidos.
- Investigación interna.
- Aislamiento de sistemas afectados.
- Revisión de privilegios.
- Comunicación pública del incidente.

Sin embargo, el caso generó cuestionamientos sobre:

- La capacidad de detección temprana.
- La efectividad del monitoreo continuo.
- La gestión de identidades y accesos.
- La supervisión de contratistas externos.

Relación con las cuatro sesiones del curso

Sesión 1: Identificación de activos y riesgos

Los alumnos deben identificar:

Activos críticos involucrados

- Identidades digitales.
- Sistemas administrativos.
- Repositorios de código.
- Infraestructura corporativa.
- Información interna.

Amenazas

- Ingeniería social.
- Robo de credenciales.
- Acceso no autorizado.
- Escalamiento de privilegios.

Vulnerabilidades

- Fatiga MFA.
- Exceso de privilegios.
- Falta de segmentación.
- Capacitación insuficiente.

Sesión 2: Análisis y evaluación del riesgo

Analizar:

Probabilidad

Alta.

La ingeniería social es una de las amenazas más frecuentes y exitosas.

Impacto

Muy alto.

Compromiso de sistemas internos y exposición pública.

Nivel de riesgo

Crítico.

Sesión 3: Tratamiento del riesgo

Posibles estrategias:

Mitigar

- MFA resistente al phishing.
- Zero Trust.
- Gestión de accesos privilegiados (PAM).
- Capacitación continua.

Transferir

- Seguros cibernéticos.

Evitar

- Eliminación de accesos innecesarios.

Aceptar

- Riesgos residuales previamente evaluados.

Sesión 4: Monitoreo, gestión de incidentes y mejora continua

Esta sesión permite analizar las principales fallas observadas en el caso.

Monitoreo continuo

Preguntas clave:

- ¿Se monitoreaban adecuadamente los eventos MFA?

- ¿Existían alertas por múltiples rechazos consecutivos?
- ¿Se detectaron accesos desde ubicaciones inusuales?
- ¿Se monitoreaban comportamientos anómalos de usuarios?

Gestión de incidentes

Preguntas clave:

- ¿La detección fue suficientemente rápida?
- ¿Se activó oportunamente el proceso de respuesta?
- ¿Existían procedimientos específicos para abuso de MFA?

Auditoría

Preguntas clave:

- ¿Una auditoría previa habría identificado privilegios excesivos?
- ¿Se revisaban periódicamente las cuentas de contratistas?
- ¿Existían revisiones de accesos privilegiados?

Mejora continua

Preguntas clave:

- ¿Qué lecciones aprendidas debieron incorporarse?
- ¿Qué controles debieron fortalecerse después del incidente?
- ¿Cómo aplicar el ciclo PDCA para evitar recurrencias?

Impactos del incidente

Operacional

- Interrupción temporal de herramientas internas.
- Restricciones de acceso durante la investigación.
- Incremento de actividades de respuesta.

Financiero

- Costos de investigación.
- Costos de remediación.
- Incremento de inversiones en seguridad.

Reputacional

- Amplia cobertura mediática.
- Pérdida de confianza de usuarios y socios.

Estratégico

- Revisión de la estrategia de gestión de identidades.
- Fortalecimiento de controles de acceso.

Información adicional para el análisis

Suponga que la organización contaba con los siguientes indicadores:

Indicador	Valor observado antes del incidente
Solicitudes MFA rechazadas por usuario por día	35
Accesos desde ubicaciones inusuales	18 eventos semanales
Cuentas privilegiadas revisadas en los últimos 6 meses	40%
Contratistas con acceso administrativo	22
Alertas de comportamiento anómalo investigadas	55%
Tiempo promedio de revisión de alertas críticas	18 horas

Asimismo, una auditoría interna realizada tres meses antes había identificado:

- Falta de revisión periódica de privilegios.
- Dependencia excesiva de MFA Push.
- Ausencia de controles adaptativos basados en riesgo.
- Monitoreo limitado de cuentas de terceros.
- Falta de indicadores específicos para abuso de MFA.

Sin embargo, las recomendaciones aún no habían sido implementadas.

Preguntas para discusión

1. Desde la perspectiva del monitoreo continuo, ¿qué señales tempranas debieron haber alertado a la organización antes de que el atacante obtuviera acceso?
2. Analizando el ciclo de gestión de incidentes (Preparación, Detección, Contención, Erradicación, Recuperación y Lecciones Aprendidas), ¿en qué fases identifica mayores debilidades y por qué?
3. Si usted fuera responsable de seguridad (CISO), ¿qué acciones inmediatas y qué acciones de largo plazo implementaría para reducir la probabilidad de un incidente similar?
4. Diseñe al menos cinco KRIs que permitan monitorear el riesgo asociado a robo de credenciales, abuso de MFA y accesos privilegiados.

Indique:

- Indicador.
 - Fórmula o métrica.
 - Umbral de alerta.
 - Acción correctiva.
5. Relacionando el caso con ISO 27001, ISO 31000, NIST CSF 2.0 y NIST SP 800-53, ¿qué controles o prácticas de gestión de riesgos hubieran reducido significativamente la probabilidad o el impacto del incidente?

Cada Grupo deberá presentar en una PPT las respuestas a las preguntas.